



# FINAL SECURITY, PERMISSIONS & ACCESS CONTROL DOCUMENT

*(Pre-Deployment Contract)*

---

## 1 GLOBAL RULES (Apply Everywhere)

These rules apply to **every view, action, and request**.

### Authentication

- ☒ All protected views require login
  - ☒ Unauthenticated users are redirected to login
  - ☒ Logout destroys session completely
  - ☒ Back button does not restore access after logout
- 

### Role Integrity

- ☒ Role assigned only at registration
  - ☒ Role is immutable for users
  - ☒ Role cannot be changed via request tampering
  - ☒ No endpoint accepts `role` after registration
  - ☒ Admin role cannot be self-assigned
- 

### Admin Override

- ☒ Admin (`is_superuser`) bypasses business rules
  - ☒ Admin access does NOT leak into normal dashboards
  - ☒ Admin uses Django Admin as primary interface
- 

## 2 USER AUTHENTICATION & MANAGEMENT

### Registration

- ☒ Email unique
  - ☒ Password hashed
  - ☒ Only Student / Instructor selectable
  - ☒ Cannot register as admin
  - ☒ Cannot inject role via request
- 

### Login

- ☒ Valid credentials only
  - ☒ Role-based redirect:
    - Student → Student Dashboard
    - Instructor → Instructor Dashboard
    - Admin → Django Admin
  - ☒ Inactive users blocked
- 

### Logout

- ☒ Logout safe when logged out
  - ☒ Double logout safe
  - ☒ Dashboard access blocked after logout
- 

## **3 DASHBOARDS**

### **Student Dashboard**

- ☒ Accessible only to students
  - ☒ Instructor blocked
  - ☒ Unauthenticated blocked
  - ☒ Admin override allowed
- 

### **Instructor Dashboard**

- ☒ Accessible only to instructors
  - ☒ Student blocked
  - ☒ Unauthenticated blocked
  - ☒ Admin override allowed
- 

## **4 COURSE MANAGEMENT**

### **Create Course**

- ☒ Instructor only

-  Student blocked
  -  Unauthenticated blocked
  -  Admin override allowed
- 

### **Edit / Delete Course**

-  Only course owner
  -  Other instructors blocked
  -  Students blocked
  -  Admin override allowed
- 

### **Course Visibility**

-  Published courses visible publicly
  -  Draft courses hidden from students & public
  -  Draft courses visible to owner instructor
  -  Admin sees all
- 

## **5 CATEGORY SYSTEM**

-  Categories managed only by admin
-  Instructors cannot create/edit categories
-  Students cannot modify categories

- ☒ Category selectable during course creation
- 

## **6 MODULE MANAGEMENT**

### **Create / Edit / Delete Module**

- ☒ Course owner only
  - ☒ Other instructors blocked
  - ☒ Students blocked
  - ☒ Admin override allowed
- 

### **Module Ordering**

- ☒ Ordered ascending
  - ☒ Duplicate order within same course
  - ☒ Order = 0 or negative
- 

## **7 LESSON MANAGEMENT & ACCESS**

### **Create / Edit / Delete Lesson**

- ☒ Course owner only
- ☒ Other instructors blocked
- ☒ Students blocked
- ☒ Admin override allowed

---

## Lesson Access (Students)

-  Must be enrolled
-  Course must be published
-  Direct URL access blocked
-  Unenrolled users blocked

---

## ENROLLMENT

### Enrollment Creation

-  Student only
-  Instructor blocked
-  Unauthenticated blocked
-  Duplicate enrollment blocked
-  Draft course enrollment blocked
-  Instructor enrolling in own course blocked
-  Admin override allowed

---

### Enrollment Effects

-  Enrollment grants lesson access
-  No enrollment → no lesson access
-  Removing enrollment revokes access

---

## 9 PROGRESS TRACKING

-  Progress auto-calculated
-  Manual progress editing blocked
-  Progress tied to lesson completion
-  Access progress without enrollment blocked
-  Admin override allowed

---

## 10 QUIZ & ASSESSMENT SYSTEM

### Quiz Visibility (Student)

-  Must be enrolled
-  Course published
-  Unenrolled blocked
-  Draft course blocked

---

### Quiz Management (Instructor)

-  Course owner only
-  Other instructors blocked
-  Students blocked
-  Admin override allowed

---

## Quiz Attempt

- ☒ Student only
- ☒ Instructor blocked
- ☒ Unauthenticated blocked
- ☒ Already attempted blocked
- ☒ Lesson not completed (if enforced) blocked

---

## Quiz Submission

- ☒ Attempt ownership validated
- ☒ Double submission blocked
- ☒ Score tampering blocked
- ☒ Attempt locked after submit

---

## 11 ADMIN PANEL

- ☒ Only staff/superuser access
- ☒ Normal users blocked
- ☒ Admin can manage:
  - Users
  - Courses
  - Enrollments

- Progress
  - Quizzes
- 

## 12 REQUEST TAMPERING & SECURITY

-  Role injection blocked
  -  Ownership injection blocked
  -  Foreign object access blocked
  -  ID guessing blocked
  -  CSRF protected
  -  Session hijack blocked
- 

## 13 ERROR HANDLING

-  403 for unauthorized access
  -  404 for hidden resources
  -  Stack traces exposed to users
  -  Graceful redirects
- 

## 14 PERFORMANCE & SAFETY

-  No N+1 queries on dashboards
-  `select_related` / `prefetch_related` applied

-  No sensitive data in templates
-  No debug mode in production

---

## **FINAL DEPLOYMENT CHECK**

If **all items above are enforced**, your LMS is:

- ✓ Secure
- ✓ Role-safe
- ✓ Permission-correct
- ✓ Deployment-ready

---

## **FINAL INTERVIEW LINE (USE THIS)**

“Before deployment, I enforced comprehensive role-based access control, ownership validation, enrollment-gated content access, and request-tampering protection across the entire system.”